API SECURITY RISK ANALYSIS REPORT

## 1. Executive Summary

This report provides a comprehensive security analysis of a publicly accessible API endpoint. The objective is to evaluate potential vulnerabilities such as lack of authentication, excessive data exposure, and absence of access control mechanisms.

The analysis reveals that the API allows unrestricted access to user-related information without any verification process. Such behavior can lead to data misuse, automated scraping, and potential security risks in real-world applications.

This report highlights key findings, evaluates associated risks, and provides actionable recommendations to strengthen API security.

## 2. Scope of Analysis

The scope of this analysis includes:

- Examination of API endpoint behavior
- Authentication and authorization checks
- Data exposure assessment
- Access control evaluation
- Identification of security risks
- Recommendation of mitigation strategies

## 3. Tools & Technologies Used

The following tools and approaches were used:

- Web Browser (for API access and inspection)
- Manual Inspection Techniques
- Documentation Tools (MS Word / PDF)

## 4. API Endpoint

- `https://jsonplaceholder.typicode.com/users`
- This endpoint returns structured user data including personal and contact details.

## 5. Methodology

The analysis was conducted using a structured approach:

1. Accessed the API endpoint using a web browser
2. Observed the data returned in JSON format
3. Evaluated whether authentication was required
4. Identified exposed data fields

5. Checked for access restrictions
6. Analyzed potential misuse scenarios
7. Documented risks and recommendations

**6. Detailed API Analysis**

**Authentication Analysis**

- The API does **not require authentication**
- No API key, token, or login mechanism is enforced
- This allows **unrestricted public access**

**Impact:**
Anyone can access the API, increasing the risk of unauthorized data usage.

**Data Exposure Analysis**

The API exposes the following user information:

- Name
- Email Address
- Phone Number
- Address

**Impact:**
Even though this is sample data, in real-world scenarios this could lead to:

- Privacy violations
- Data scraping
- Social engineering attacks

**Access Control Analysis**

- No access restrictions are applied
- No role-based or permission-based controls

**Impact:**
All users (authorized or not) can access the same data.

**Input Validation Analysis**

- No visible validation mechanisms
- No restrictions on query manipulation

**Impact:**
Could lead to:

- Injection attacks (in real APIs)

- Data manipulation
- Unexpected system behavior

**7. Identified Security Risks**

The following risks were identified:

- Unrestricted public access to API
- Exposure of user data
- Absence of authentication mechanisms
- Lack of access control
- Potential for automated data scraping

**8. Risk Level Assessment**

**Overall Risk Level: MEDIUM**

Although the API does not expose highly sensitive data (like passwords), the absence of basic security controls increases the risk of misuse and exploitation.

**9. Real-World Impact**

If implemented in a real application, such vulnerabilities could result in:

- Unauthorized access to user information
- Data leakage and privacy breaches
- Increased risk of phishing and social engineering attacks
- Abuse through automated bots and scripts

**10. Recommendations & Mitigation Strategies**

To improve API security, the following measures are recommended:

**Authentication & Authorization**

- Implement API key or token-based authentication
- Use OAuth or JWT for secure access

**Access Control**

- Apply role-based access control (RBAC)
- Restrict access to sensitive endpoints

**Data Minimization**

- Avoid exposing unnecessary user information
- Mask sensitive data fields

**Input Validation**

- Validate all incoming requests
- Sanitize inputs to prevent injection attacks

**Rate Limiting**

- Limit number of API requests per user
- Prevent abuse and automated attacks

jsonplaceholder.typicode.com/users

Pretty-print


```
[
  {
    "id": 1,
    "name": "Leanne Graham",
    "username": "Bret",
    "email": "Sincere@april.biz",
    "address": {
      "street": "Kulas Light",
      "suite": "Apt. 556",
      "city": "Gwenborough",
      "zipcode": "92998-3874",
      "geo": {
        "lat": "-37.3159",
        "lng": "81.1496"
      }
    },
    "phone": "1-770-736-8031 x56442",
    "website": "hildegard.org",
    "company": {
      "name": "Romaguera-Crona",
      "catchPhrase": "Multi-layered client-server neural-net",
      "bs": "harness real-time e-markets"
    }
  },
  {
    "id": 2,
    "name": "Ervin Howell",
    "username": "Antonette",
    "email": "Shanna@melissa.tv",
    "address": {
      "street": "Victor Plains",
      "suite": "Suite 879",
      "city": "Wisokyburgh",
      "zipcode": "90566-7771",
      "geo": {
        "lat": "-43.9509",
        "lng": "-34.4618"
      }
    },
    "phone": "010-692-6593 x09125",
    "website": "anastasia.net",
    "company": {
      "name": "Deckow-Crist",
      "catchPhrase": "Proactive didactic contingency",
      "bs": "synergize scalable supply-chains"
    }
```


jsonplaceholder.typicode.com/users

Pretty-print


```
  },
  {
    "id": 2,
    "name": "Ervin Howell",
    "username": "Antonette",
    "email": "Shanna@melissa.tv",
    "address": {
      "street": "Victor Plains",
      "suite": "Suite 879",
      "city": "Wisokyburgh",
      "zipcode": "90566-7771",
      "geo": {
        "lat": "-43.9509",
        "lng": "-34.4618"
      }
    },
    "phone": "010-692-6593 x09125",
    "website": "anastasia.net",
    "company": {
      "name": "Deckow-Crist",
      "catchPhrase": "Proactive didactic contingency",
      "bs": "synergize scalable supply-chains"
    }
  },
  {
    "id": 3,
    "name": "Clementine Bauch",
    "username": "Samantha",
    "email": "Nathan@yesenia.net",
    "address": {
      "street": "Douglas Extension",
      "suite": "Suite 847",
      "city": "McKenziehaven",
      "zipcode": "59590-4157",
      "geo": {
        "lat": "-68.6102",
        "lng": "-47.0653"
      }
    },
    "phone": "1-463-123-4447",
    "website": "ramiro.info",
    "company": {
      "name": "Romaguera-Jacobson",
      "catchPhrase": "Face to face bifurcated interface",
      "bs": "e-enable strategic applications"
    }
  },
```

API Response :

The screenshot shows that the API endpoint is publicly accessible without authentication and exposes user data such as email, phone, and address.

Observation:

The API does not require authentication and exposes structured user data, which can lead to data misuse if deployed in a real-world scenario.